



Cyber Attacks on IT-OT Communication Networks

Ioannis Semertzis, Dr. Alex Stefanov

MSc EE & MSc SET, Course EE4410

Faculty of Electrical Engineering, Mathematics and Computer Science, **TU Delft**

Lecture 4 on May 13, 2025

Disclaimer & Ethics

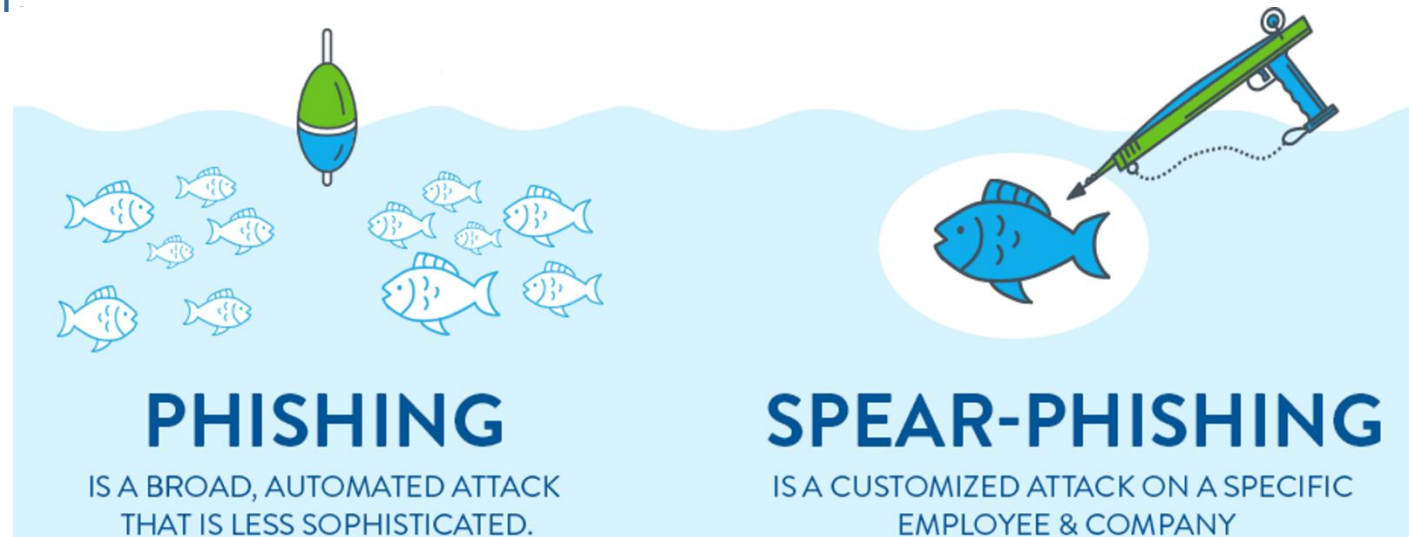
1. **All information provided in the course is for educational purposes only.** The lecturer(s) and teaching assistant(s) are not responsible for any misuse of the information.
2. The course does not promote and is strongly against illegal activities such as unethical hacking, cracking and piracy.
3. **Do not attempt to violate the law with anything contained in the course.** Do not abuse the material provided and be responsible.
4. By participating in the course, **you (student) must accept that you will only lawfully use the material and knowledge you got from this course.**
5. Any actions and / or activities related to the material contained within this course are solely your (student) responsibility. **The misuse of the information in this course can result in criminal charges brought against the persons in question.**
6. The lecturer(s) and teaching assistant(s) will not be held responsible in the event any criminal charges are brought against any individuals misusing the information from this course to break the law.



Cyber Attacks on IT Systems

Phishing and Spear Phishing

- A **phishing** scam is a type of e-mail or web security threat that **tries to trick an unsuspecting user into visiting a website and entering confidential personal information** or replying to an e-mail with such information, often a username and password, or banking or credit card details
- A variant attack called **spear phishing** is a targeted type of phishing attack that **includes information familiar to the user and could appear to be from a trusted source** such as a company from which the user has purchased a product in the past, a financial service that the victim has used previously, or even a specific trusted user.



Source: [reliancebank.com.au](https://www.reliancebank.com.au)

Malware

- Malware is a malicious code / software intentionally designed to cause damage to a computer, server, client or computer network
 - Malware often masquerades as part of useful software/message/information
 - Malware exploits existing vulnerabilities on systems making quiet and easy entry
- Some malicious programs need host programs to hide their tracks
 - Trojan horses, spyware, viruses, and rootkits
- Some can exist and propagate independently
 - Worms, automated viruses and zombies



Source: <https://www.androidbeat.com/>

Virus

- Self-replicating code attached to some other code
- Propagating itself and carries a payload:
 - Carries code to make copies of itself
 - Modifies the OS or the application's portable executable (PE) files
 - Performs some covert task



Source: antivirus.comodo.com

Trojan

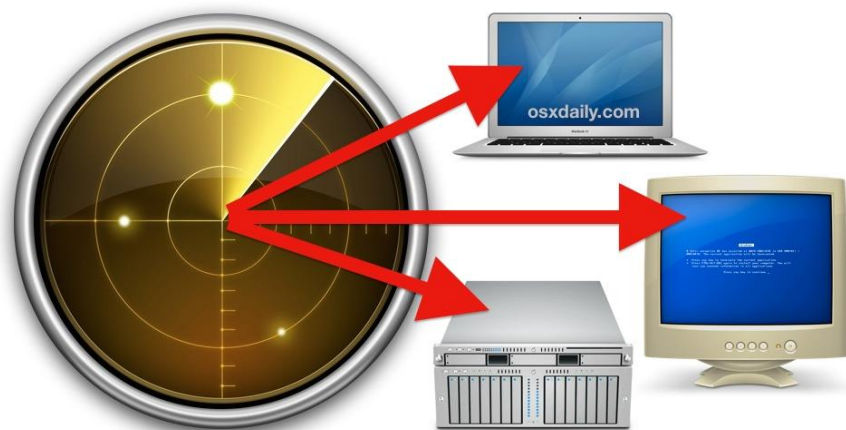
- A Trojan is a program with hidden malware
- Trojan used to propagate a virus/worm or install a backdoor
- Trojan can provide backdoors
 - Secret entry point into a program or system
 - Allows those with backdoor access to bypass usual security procedures



Source: <https://www.istockphoto.com/>

Active Reconnaissance

- Active reconnaissance is **active information gathering**, directly engaging with the target
 - Example, gathering information about
 - ✓ What ports are open on a particular target
 - ✓ What services they are running
 - ✓ What operating system they are using
 - The techniques involving active information gathering are very “noisy”
- These activities can easily be detected by IDS, IPS, and firewalls, and generate a log of their presence



Source: osxdaily.com

Network & Host Discovery

- Attackers use various methods for enumerating and scanning a target
 - Goal is to gain as much information about the alive targets on a network as possible
 - ✓ Host discovery: know what targets are alive on a network
 - ✓ Scanning for open ports: discovering TCP and UDP open ports on the target host or network (potential entry points in systems)
 - ✓ Service and version detection
 - ✓ OS detection
 - ✓ Bypassing firewalls (one of the most challenging tasks with port scanning is to evade firewalls and IDS / IPS mechanisms)



Source: info-savvy.com

[R. Baloch. (2015). Ethical hacking and penetration testing guide. CRC Press.]

Network & Host Discovery: Target Enumeration

- Enumeration is defined as the process of extracting usernames, machine names, network resources, and services from a system
 - In this phase, the attacker creates an active connection to the system and performs directed queries to gain more information about the target
 - The gathered information is used to identify vulnerabilities or weak points in a system's security
 - Information enumerated by intruders
 - ✓ Network resource and shares
 - ✓ Users and groups
 - ✓ Routing tables
 - ✓ Auditing and service settings
 - ✓ Machine names
 - ✓ Applications
 - ✓ DNS details



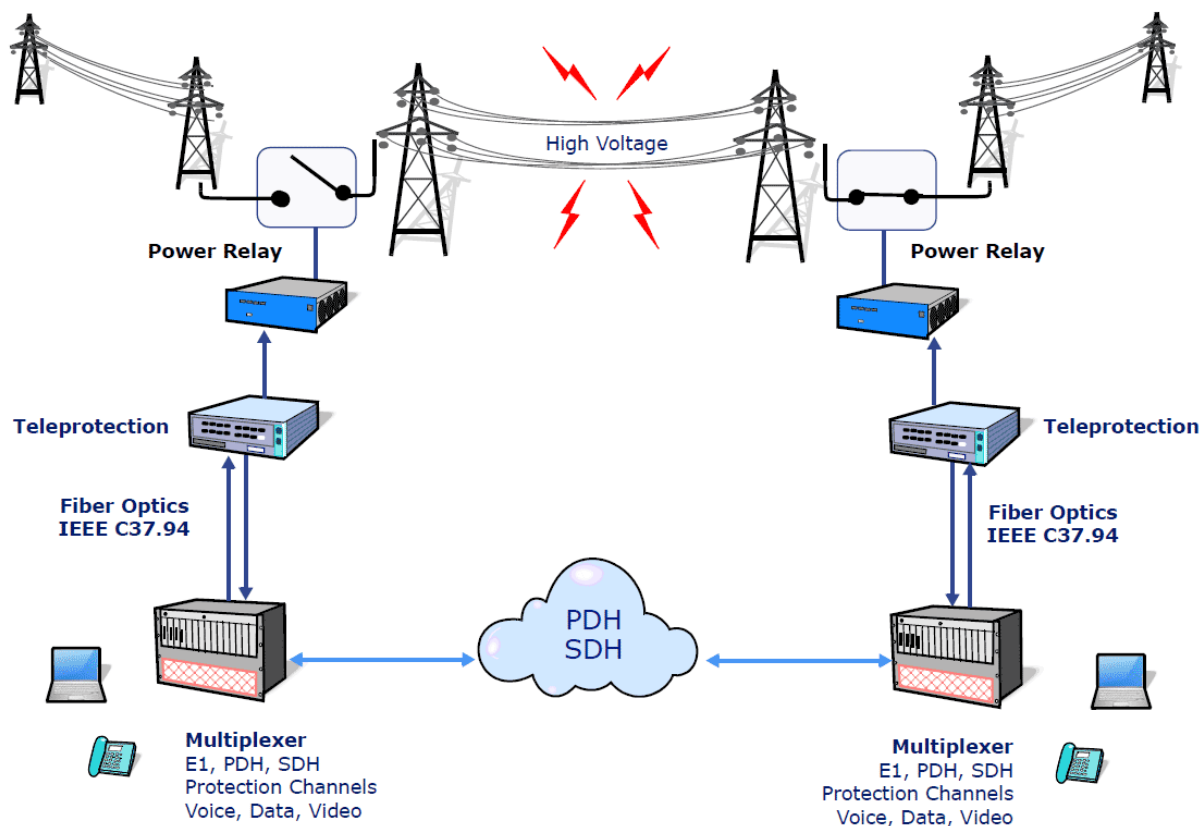
Source: info-savvy.com



Cyber Attacks on IEC 61850 in Digital Substations

Power System Automation & Protection

- Modern power system protection based on multipurpose digital relays
- Shift towards newer interoperable standards for automation and protection, e.g., IEC 61850

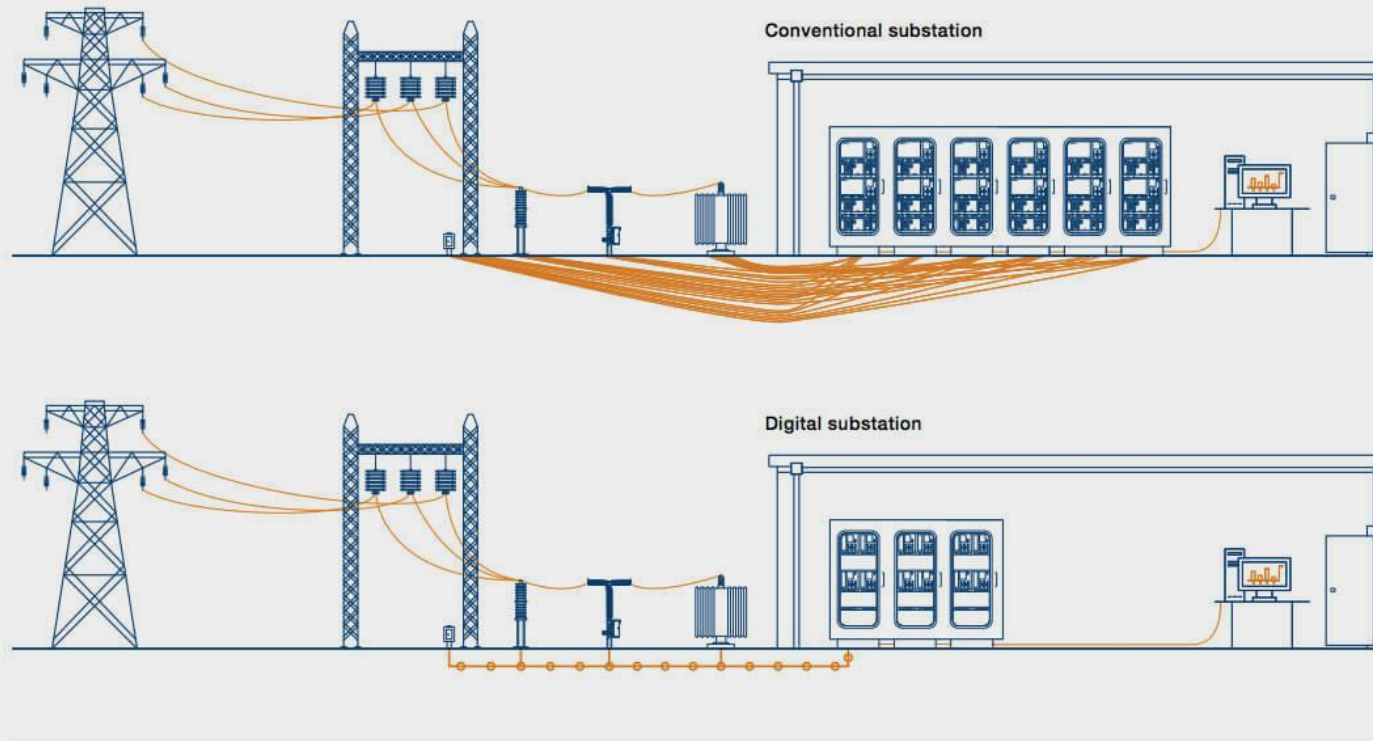


Source: ABB, Siemens

Source: "Protection Architecture" by Jose Manuel Caballero
CC BY-SA 3.0

Digital Substations & IEC 61850 Standard

Digital substations replace many point-to-point copper cables with a single fiber-optic process bus.



*The digital process bus is managed by the IEC 61850-2 subsection of the standard for digital substation communication. It underpins the true digital substation and requires a new approach to substation architecture, design and construction.

Source: ABB, IEC 61850 in Digital Substation and Cyber security

IEC 61850 protocols

- Generic Object-Oriented Substation Event (GOOSE)
- Sampled Values (SV)
- Manufacturing Messaging Service (MMS)

IEC 61850 cyber threats

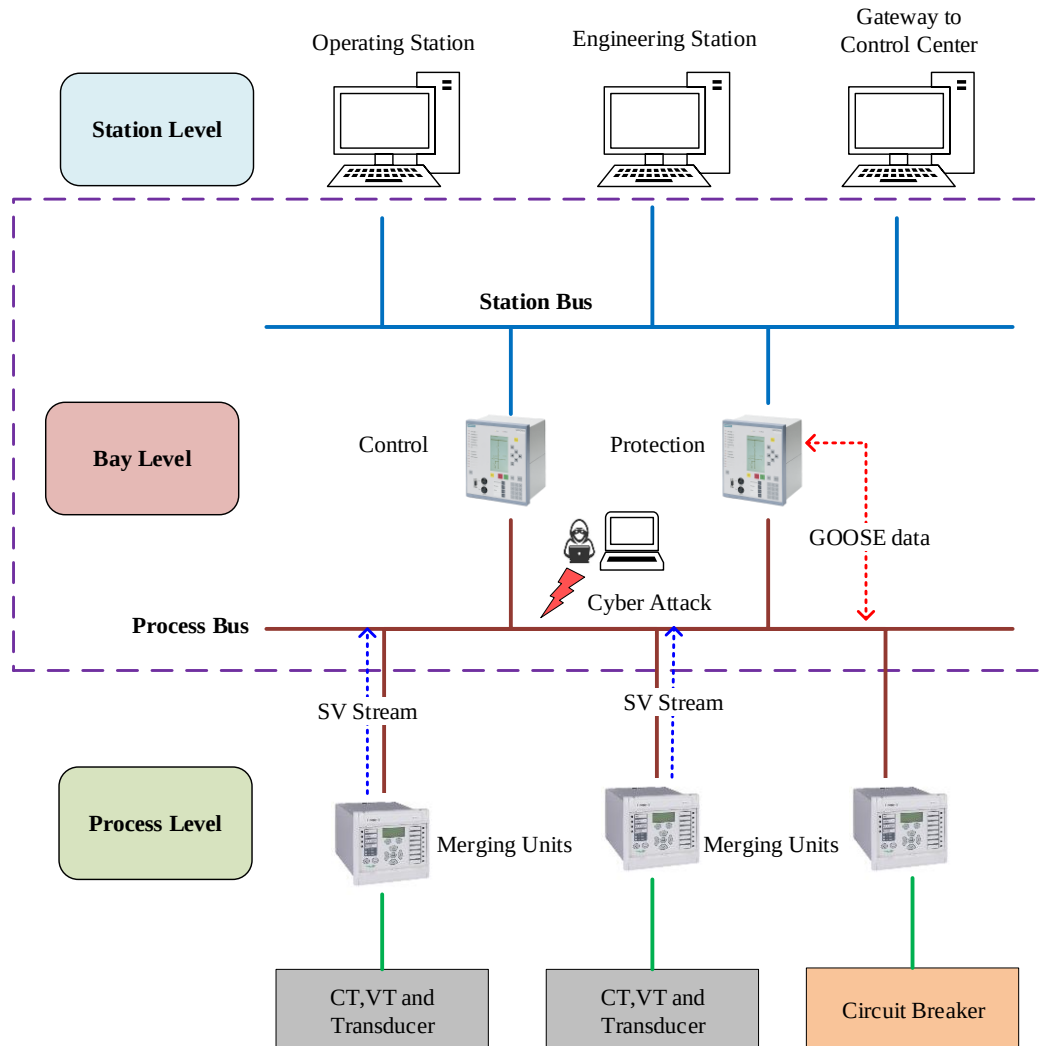
- GOOSE and SV susceptible to spoofing and man-in-the-middle attacks
- MMS susceptible to session hijacking, replay, and packet sniffing and spoofing attacks

IEC 62351-6 standard developed to secure IEC 61850 protocols

Source:

<https://www.windpowerengineering.com/going-digital-look-modern-substation/>

Digital Substation Architecture



Based on IEC 61850: Ethernet communication

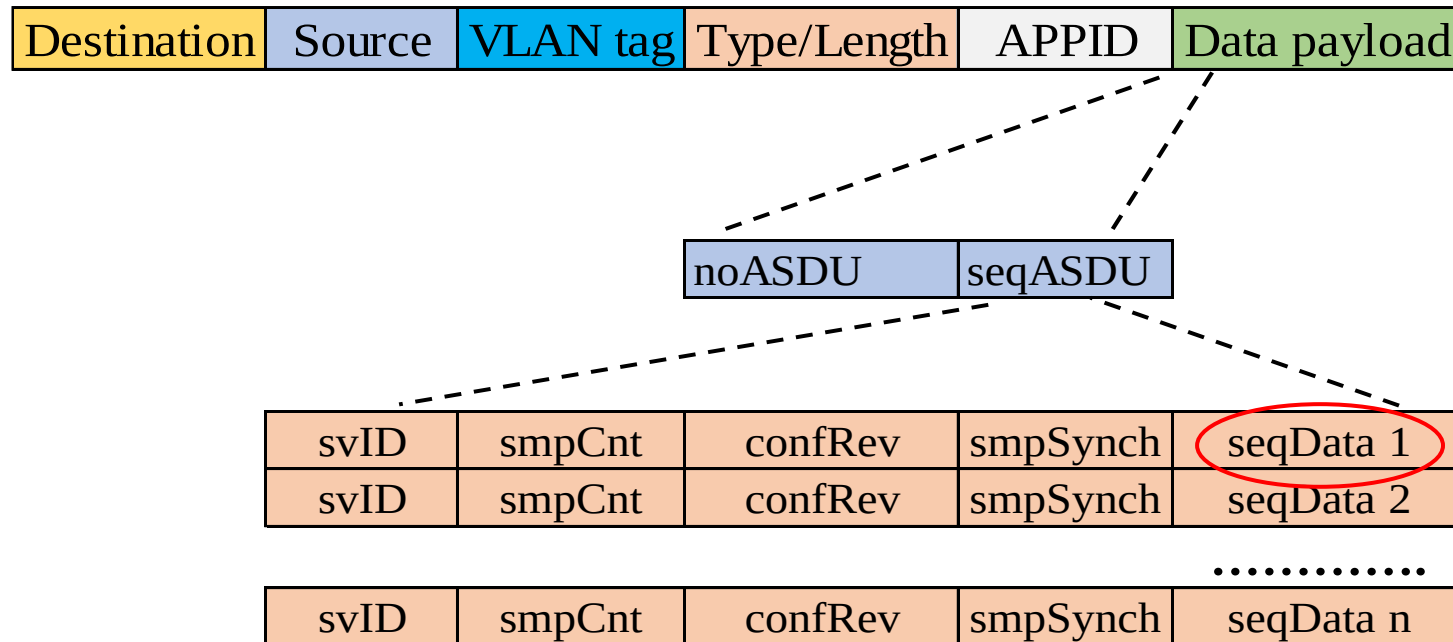
Lack of data encryption

Vulnerable to cyber attacks

Legend

- GOOSE: Generic Object Oriented Substation Event
- SV: Sampled Values
- CT: Current Transformer
- VT: Voltage Transformer

IEC 61850: Sampled Values (SV) Protocol



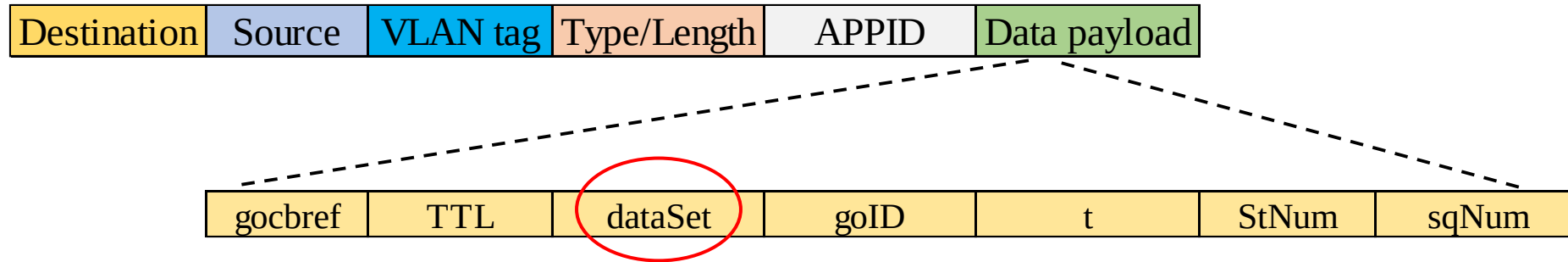
Legend

- SV: Sampled Values
- APPID: Application ID
- ASDU: Application Service Data Unit
- noASDU: Number of ASDUs
- svID: Sampled Values IDentifier
- smpCnt: Sampled Values Count
- confRev: Configuration Revision
- smpSynch: Sampled Values Synchronization
- seqData: Sequence of Data

seqData contains direct sampled measurements, i.e., voltages & currents

Typical update rate: 80 samples/cycle ~ 4 kHz for a 50 Hz system

IEC 61850: GOOSE Protocol



Communicate critical substation events in real-time, e.g., tripping circuit breakers

- Uses Ethernet frames (layer 2)

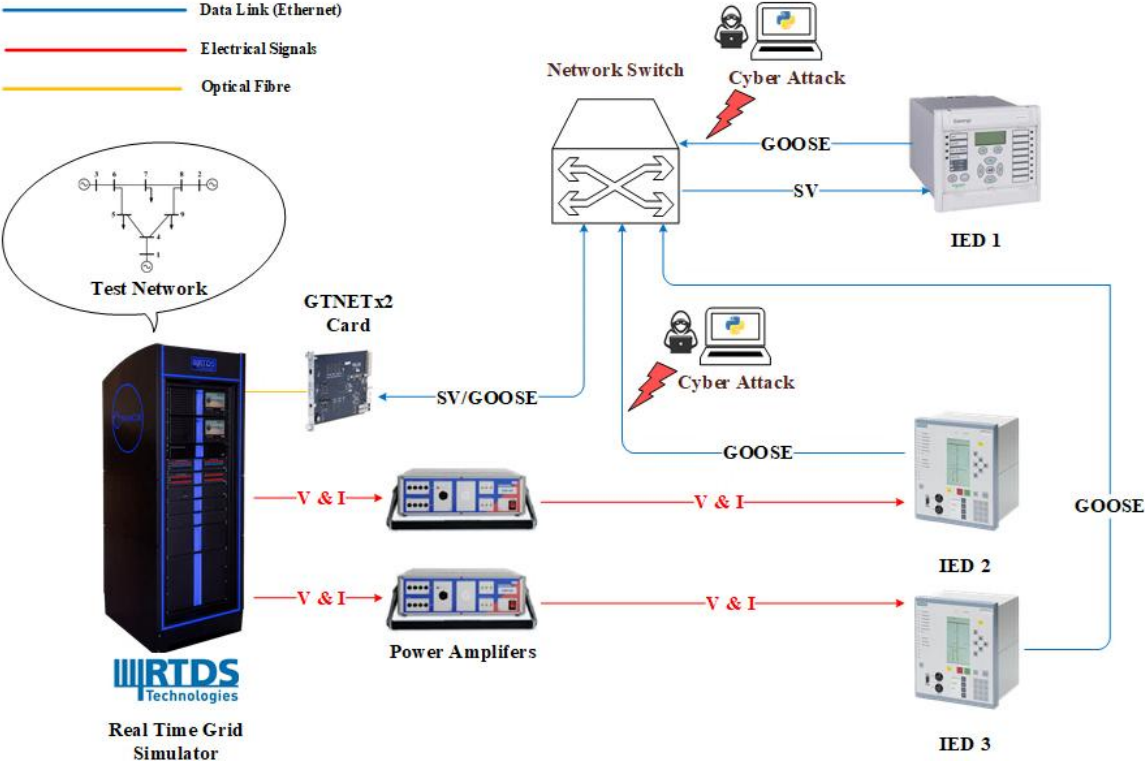
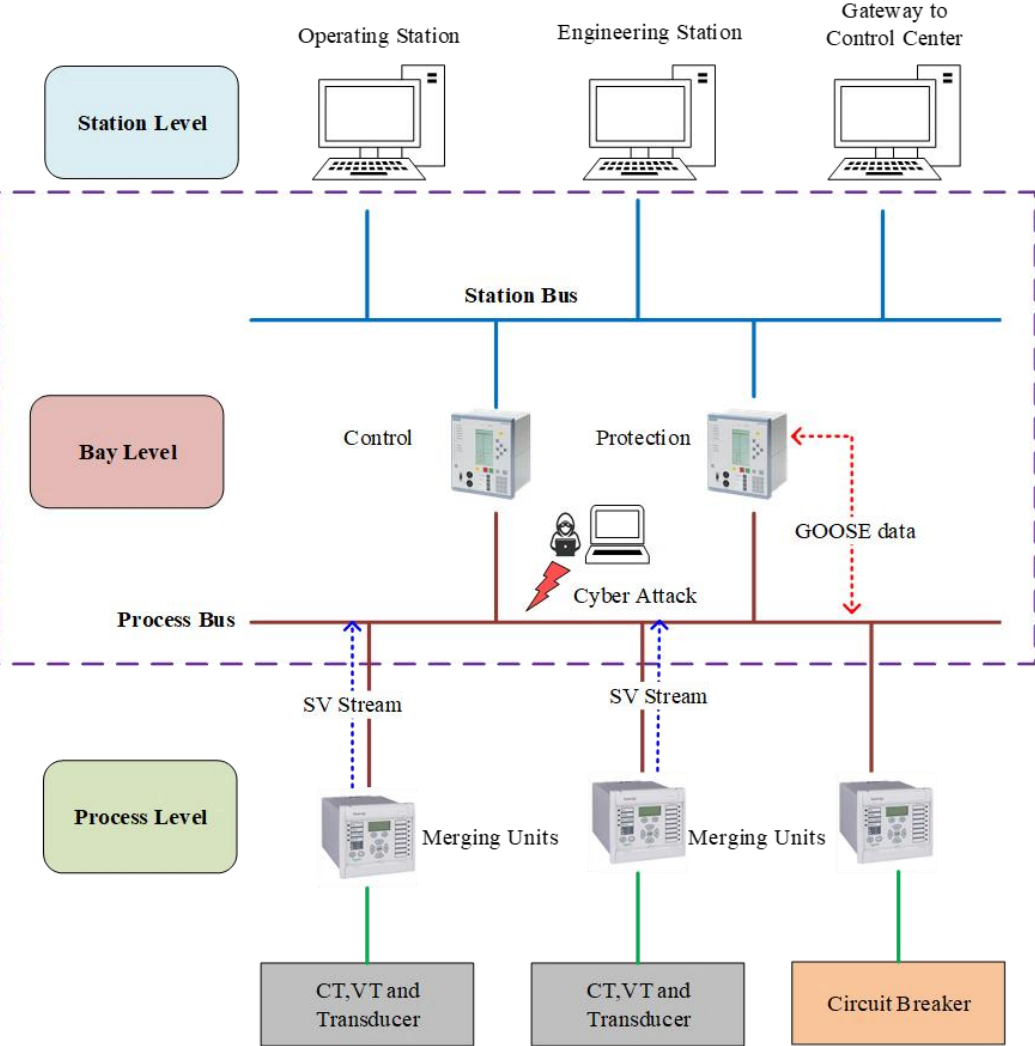
Publisher-subscriber mechanism

dataSet contains trip signals & circuit breaker statuses

Legend

- GOOSE: Generic Object Oriented Substation Event
- VLAN: Virtual Local Area Network
- APPID: Application ID
- gocbref: GOOSE Control Block Reference
- TTL: Time to Live
- goID: GOOSE ID
- stNum: Status Number
- sqNum: Sequence Number

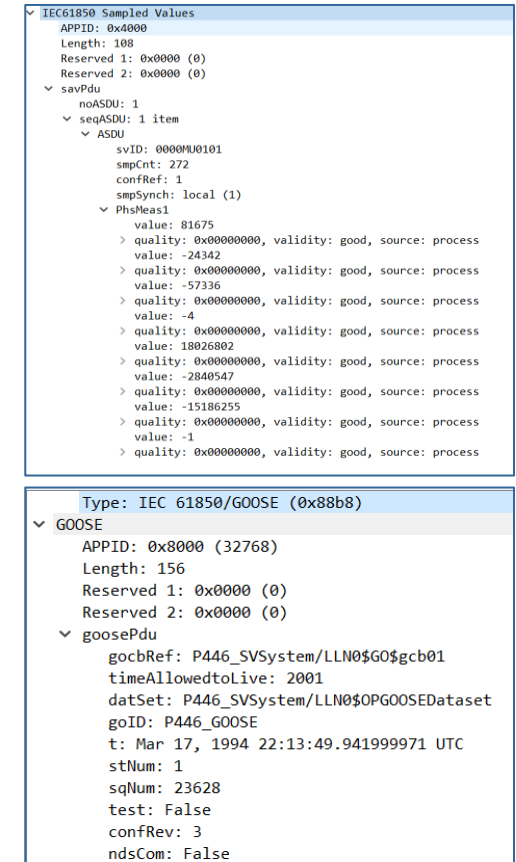
Cyber Attacks on IEC 61850 in Digital Substations



Cyber Attacks on IEC 61850 in Digital Substations: Stage 1

Network reconnaissance

- Monitor network traffic for GOOSE and SV data
- Wireshark used to capture network data for weaponization
- Capture and record payload of SV and GOOSE
- Wireshark promiscuous mode: possible to monitor all traffic on interface



Wireshark snippets of a captured SV and GOOSE data frame

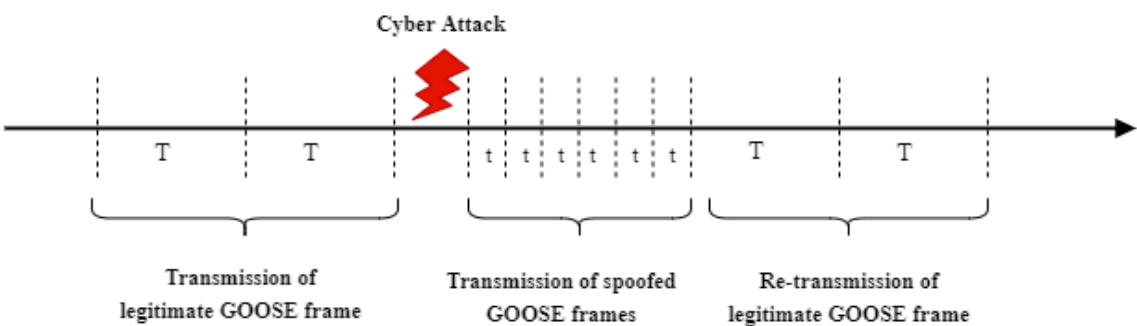
Cyber Attacks on IEC 61850 in Digital Substations: Stage 2

Cyber attack execution

- Custom Python script based on ‘Scapy’ networking library
- Inject spoofed IEC 61850 traffic into substation network at high rate
- Cause blocking of protection relays and malicious opening of circuit breakers

Spoofing of GOOSE data frames

Normal operation GOOSE frame	Cyber attack: Spoofed GOOSE frame
gocbRef: P446_SVSystem/LLN0\$GO\$gcb01	gocbRef: P446_SVSystem/LLN0\$GO\$gcb01
timeAllowedtoLive: 2001	timeAllowedtoLive: 5
t: Mar 28, 1994 03:42:25.531999945 UTC	t: Mar 20, 1994 22:04:09.076999962 UTC
stNum: 95	stNum: 99
sqNum: 80850	sqNum: 0
numDatSetEntries: 10	numDatSetEntries: 10
allData: 10 items	allData: 10 items
Data: boolean (3)	Data: boolean (3)
boolean: False	boolean: True



Cyber Attack Impact

- Result of spoofing cyber attacks on IEC 61850 protocols
 - GOOSE: opens circuit breakers
 - GOOSE: disables interlocking and opens disconnectors on load, leading to a fault
 - SV: fabricates abnormal conditions for voltage, frequency and ROCOF, leading to protection tripping
 - SV: blocks protection relays

Pseudocode 1: Injection of spoofed IEC 61850 traffic

```
Monitor network interface;  
Filter packet based on type 0x88b8 (GOOSE);  
Filter packet based on type 0x88ba (SV);  
Capture filtered packets as  $p_{cap}$  ;  
 $i = 0$ ,  $n = \text{number of } p_{cap}$  ;  
 $src = \text{source MAC address}$ ;  
 $dst = \text{destination MAC address}$ ;  
while ( $i < n$ ) do  
     $p_{spoof} = \text{Get and modify payload of } p_{cap}$ ;  
    send packet ( $src$ ,  $dst$ , VLAN,  $p_{spoof}$ );  
     $i++$ ;  
end
```



Mitigation and Cyber Security of Digital Substations

IEC 62351-6 standard: cyber security of protocols in IEC 61850

- Additional fields with RSA-based digital signature to ensure data integrity
- Usage of Hash-based Message Authentication Codes (HMACs) such as SHA-256 to check integrity of 61850 data frames
- Lack of information on certificates to be used for signatures

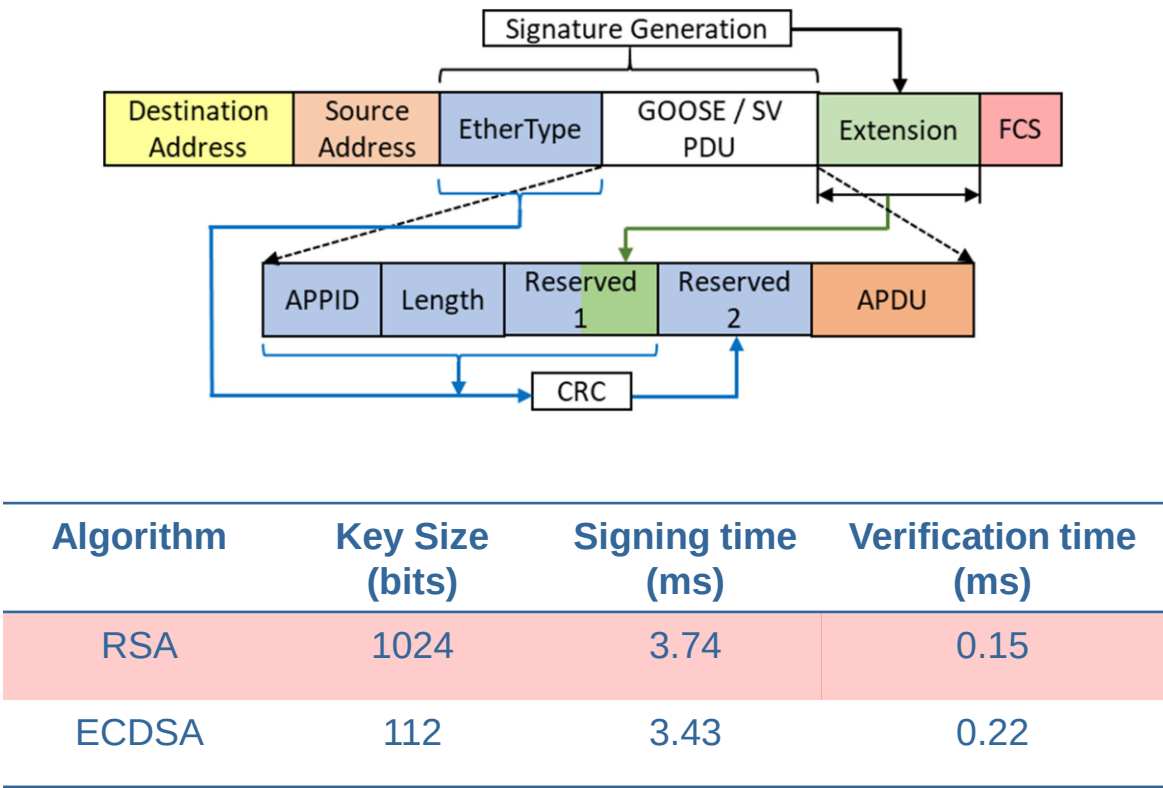
4ms strict real-time requirement for protection hard to meet while ensuring cyber security

IEC 62351-6-2 standard under development.

Mandatory use of HMAC-SHA256 and AES-GMAC-256

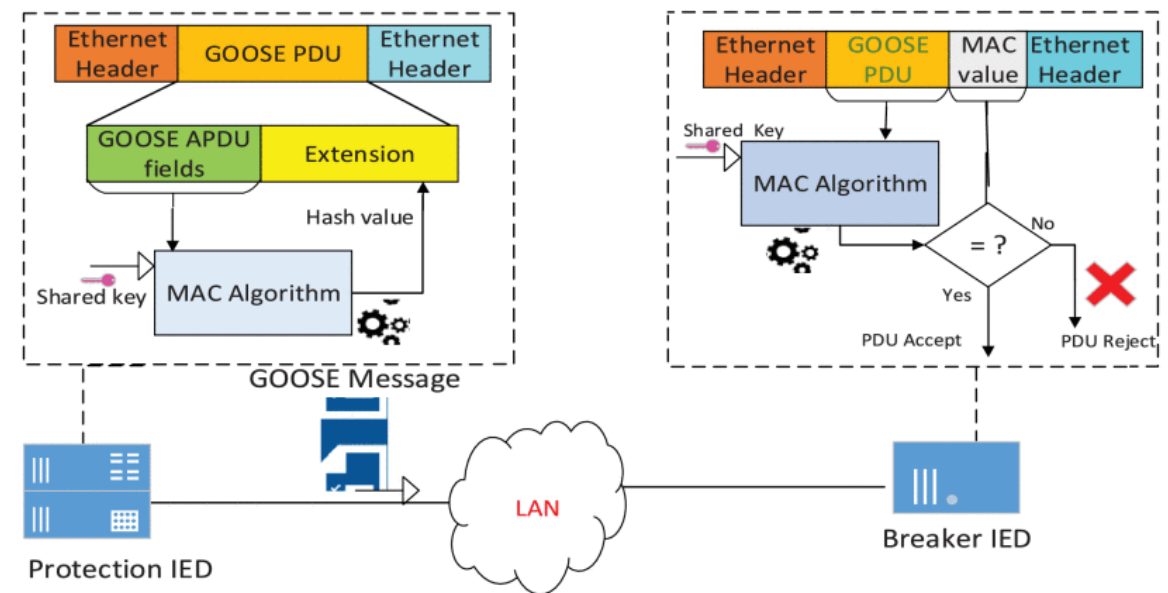
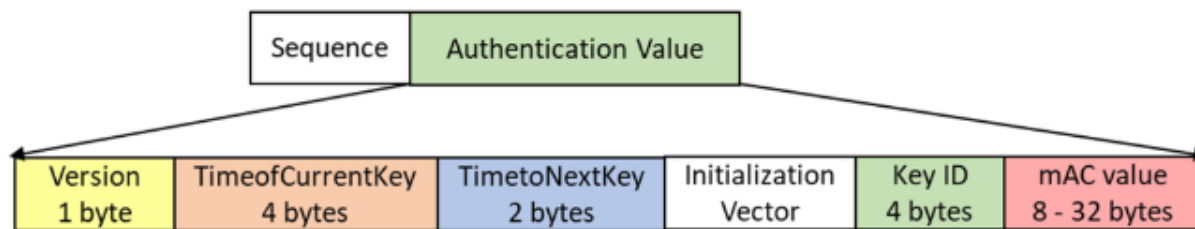
IEC 62351-6: Digital Signatures

- IEC 62351-6:2007 proposes use of Digital Signature (DS) scheme
- DS generated by SHA256 and signed by RSA algorithms
- Appended as extension to GOOSE/SV frame
- Provides security against unauthorised data access, tampering, replay attacks
- Unable to meet latency requirements ~3-4 ms



IEC 62351-6: Message Authentication Codes (MAC)

- DS is replaced by MAC value in the extension field of extended GOOSE/SV frame
- SHA256 or AES used as MAC algorithms
- Similar to symmetric encryption: **same private key** used for generation and verification of MAC values
- Able to meet 3-4ms latency requirements for time critical applications



IEC 62351-6: Message Authentication Codes (MAC)

Algorithm	Computational Time (micro s)	Latency (micro s)	
		Average	Max
HMAC-SHA-256	14.3	75.7	78.0
AES-GMAC-64	6.6	73.0	75.3
AES-GMAC-128	7.0	74.9	77.1



Cyber-Physical System Data Correlation

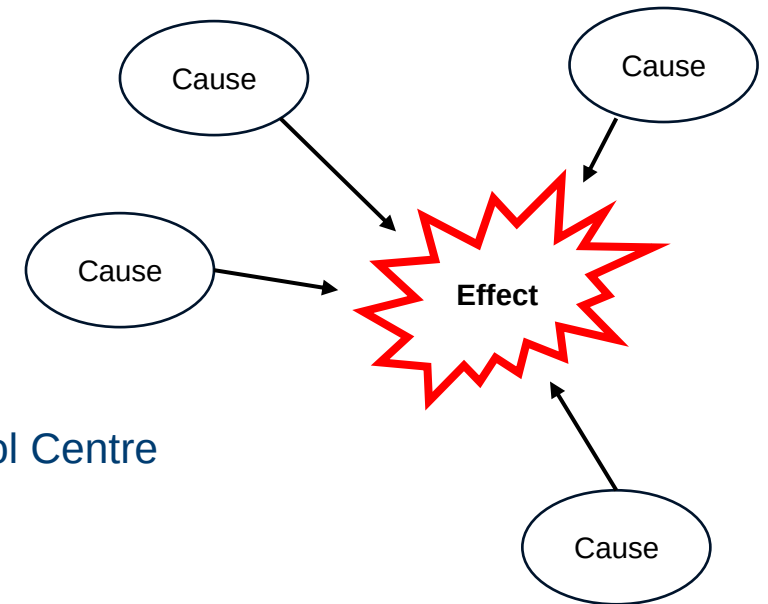
Cyber-Physical Event Distinction Problem

- Cyber attacks can impact power system operation by targeting digital substations
- The physical effects of the cyber attacks can be:
 - Component loss
 - Outages
 - Cascading failures
 - Damage to equipment
 - etc.
- But there are always non-cyber attack failures
 - Example: Substation failure in the Netherlands (2023)



Cyber-Physical Event Distinction Problem

- Example: A line circuit breaker opens in the digital substation
- Possible causes:
 1. Short-circuit in the transmission line and tripping of protection relay
 2. Spoofing attacks on IEC 61850 GOOSE or SV protocols
 3. IED or circuit breaker malfunction
 4. Open command sent by the SCADA operator – either local or from the Control Centre
 5. Man-in-the-Middle attack
- How to differentiate between cyber attacks and faults on digital substations?



Cyber-Physical Data Correlation: Measurements in the Control Centre

- System operators in Control Centre use power system measurements for situational awareness
- Measurements are used in Control Centre for various applications:
 - Short-circuit detection and distinction
 - Power system stability issues
- Depending on sampling rate of used technology (e.g., SCADA or PMU), monitoring capabilities could be enhanced:
 - A high sampling rate of many samples per cycle could be utilized for detecting and classifying events such as faults
 - Low-sampling rate offered by conventional SCADA systems, lack these capabilities

Cyber-Physical Data Correlation: Power System Measurements Limitation

- The amount of data is one thing, but will it enable the distinction between faults and cyber attacks?
 - Short-circuits are the most common category of a physical fault. What is a valid assumption to form a correlation strategy?
 - Short circuits have a distinct behavior:
 - ✓ During fault duration, the current on the faulted line increases significantly while the bus voltage is dropped
 - ✓ Can we use this reasoning for distinction, utilizing only power system measurements?
 - ✓ Cyber attackers can target the feeder bays even when the feeder circuit breakers are closed. This can result in a bolted busbar fault and an electric arc in the substation.
- How about the sequence of events?

Cyber-Physical Data Correlation: Necessity of Correlation

- Correlation of power system measurements and communication network traffic for distinction

- Let's consider the sequence of a short-circuit in a digital substation

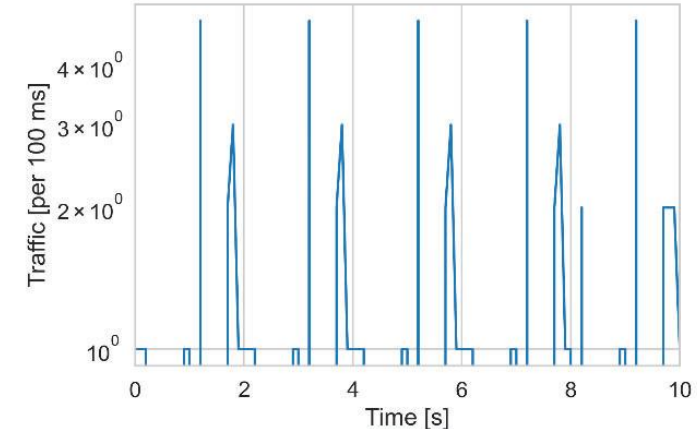
- ✓ A physical fault occurs – Voltage and current measurements collected via the measurement transformers in the field capture the deviation
- ✓ The protection IEDs trip and issue IEC 61850 GOOSE packets to the CBs
- ✓ Circuit breaker(s) open, clearing the fault

- GOOSE spoofing attack on a digital substation

- ✓ No physical fault – no deviation in power system measurements
- ✓ Malicious opening of CBs, as a result of the injection of GOOSE messages in the network traffic
- ✓ Power system measurements altered as the disconnection occurs

Cyber-Physical Data Correlation: Statistical Methods for Classification

- OT communication traffic is less stochastic compared to IT, with distinct patterns that occur periodically



- Auto-Regressive Moving Average method is widely used to linearly model and predict stationary univariate time series
 - Time series data can be referred to as stationary if their properties, e.g., mean and variance, are time-independent
 - Given a discrete-time, stationary, and univariate time series $\{x[k]\}$, $k \in \mathbf{Z}$, the ARMA model will be:

$$\hat{x}[k] = c + \vartheta_1 x[k-1] + \dots + \vartheta_p x[k-p] + \epsilon[k] + \rho_1 \epsilon[k-1] + \dots + \rho_m \epsilon[k-q]$$

Where c is constant, ϑ_{1-p} , ρ_{1-m} are learnable parameters, $\epsilon[t]$ is a white noise signal, $\hat{x}[k]$ is the predicted signal at time k , and p, m are the autoregressive and moving average orders, respectively

Cyber-Physical Data Correlation: Statistical Methods

- Is ARMA suitable for this application? Answer: No
- Why not? Answer: An ARMA model cannot capture the seasonality, i.e., patterns that repeat over a number of time periods
- The model can overcome the non-stationarity imposed by the seasonality in the data by using Seasonal ARMA (SARMA)
 - Given a discrete-time, stationary, and univariate time series $\{x[k]\}, k \in \mathbf{Z}$, the seasonal autoregressive SARMA model will be:

$$\hat{x}[k] = c + \varphi_1 x[k - s] + \cdots + \varphi_p x[k - p * s] + \epsilon[k]$$

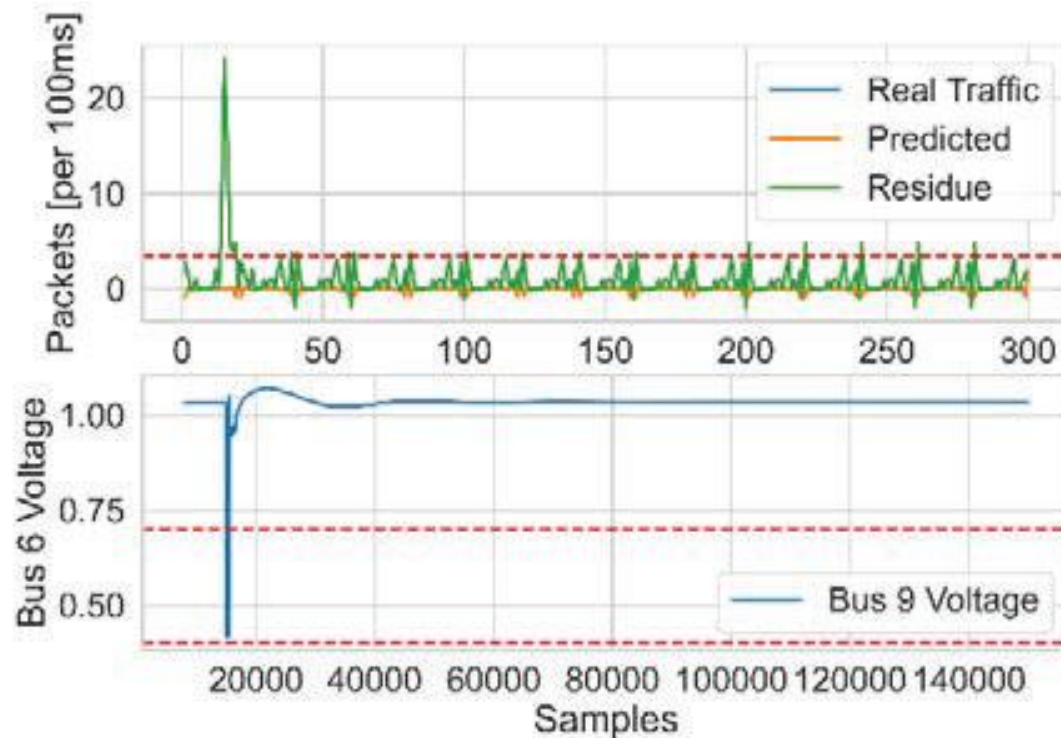
- The seasonal moving average component of SARMA model will be:

$$\hat{x}[k] = \theta_1 \epsilon[k - s] + \cdots + \theta_q \epsilon[k - q * s]$$

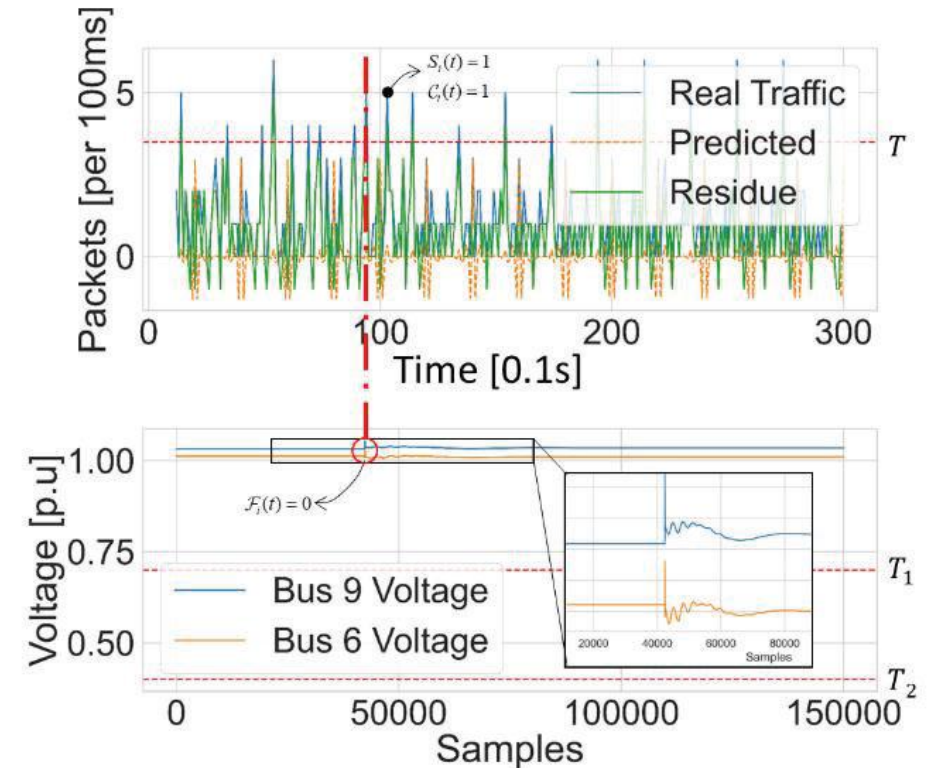
Where c is constant, $\varphi_{1-p}, \theta_{1-m}$ are learnable parameters, $\epsilon[t]$ is a white noise signal, $\hat{x}[k]$ is the predicted signal at time k , s is the seasonal period, and p, m are the autoregressive and moving average orders, respectively

Cyber-Physical Data Correlation: Applying SARMA

- Correlation of power system measurements and communication network traffic for distinction



Predicted GOOSE traffic throughput using SARMA for the case of fault



Predicted GOOSE traffic throughput using SARMA for the case of cyber attack



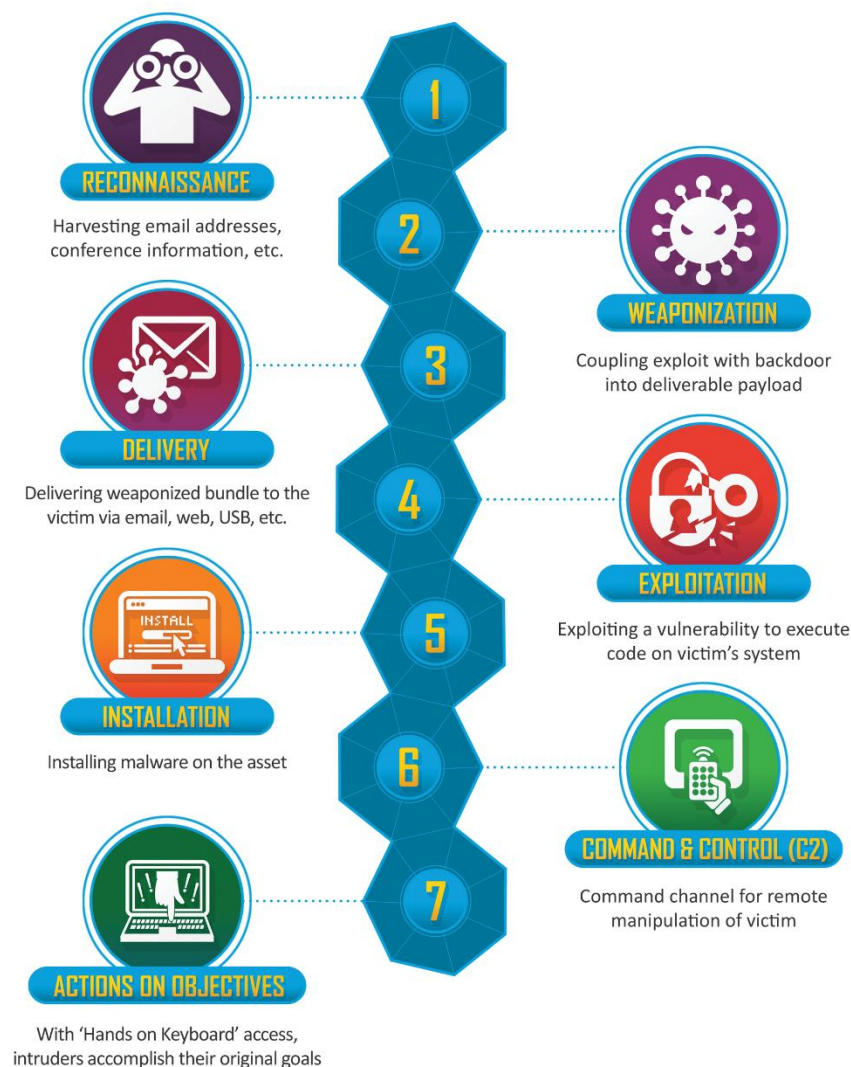
Study Case: Cyber Attacks on Power Grid in Ukraine 2015

2015 Cyber Attack on Power Grid in Ukraine in Brief

- Power outage on 23rd December 2015 at 3.35 pm.
- Illegal access and control of SCADA system caused the power outage
- Seven 110 kV and twenty-three 35 kV substations were disconnected from the grid for three hours
- The outage affected approximately 225,000 customers from three distribution system operators (oblenegros)



Attack Stages Overview



1. Passive Reconnaissance
2. Spear Phishing Email
3. Weaponization BlackEnergy3 Malware
4. Credential Theft from Databases
5. Remote Access Through VPN
6. Remote Terminal Unit (RTU) Firmware Modification
7. Disable UPS Power Backup Mechanism
8. *KillDisk* Erase Hard Disks
9. Telephone (Call Centre) Denial-of-Services
10. Remote Control SCADA HMI

Attack preparation

Increase attack severity

Final action and objectives

1. Passive Reconnaissance

- There are no reports of observed reconnaissance in Ukraine 2015 attack
- Passive Reconnaissance:
 - Passive information gathering from open sources without direct interaction with targeted system
- Attackers searched information about the Ukrainian Ministry of Energy
- Sent emails and malicious files pretending to be from the Ukrainian Ministry of Energy



<http://mpe.kmu.gov.ua/>

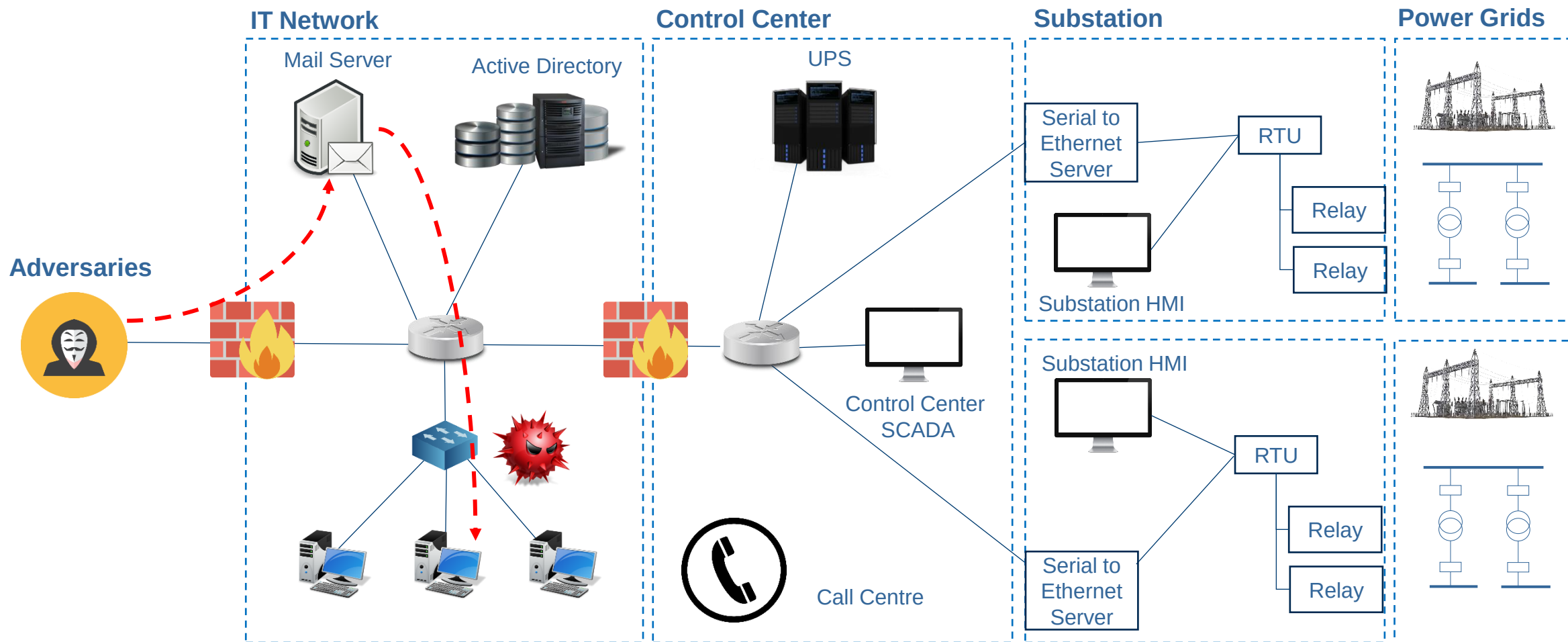


2. Spear Phishing Emails

- Spear phishing is phishing with specific targets
- March 2015 spear phishing emails targeted Ukrainian grid operators
- Official email from the Ukrainian Ministry of Energy containing Microsoft Excel attachment
- Microsoft Excel macro triggered installation of BlackEnergy3 malware

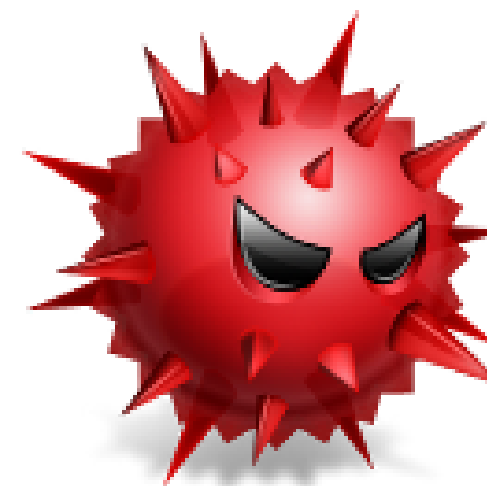


2. Spear Phishing Emails



3. BlackEnergy Malware Overview

- BlackEnergy was first reported in 2007 (named BlackEnergy1)
- BlackEnergy1 malware used for Distributed Denial of Service (DDoS) attacks
- 2nd generation BlackEnergy2 emerged in 2010
- BlackEnergy2 capabilities are data exfiltration and network traffic monitoring
- Latest Version of BlackEnergy is BlackEnergy3 (2014-2015)
- BlackEnergy3 is known for crimeware



3. BlackEnergy3 Exploits Excel Macro Vulnerabilities

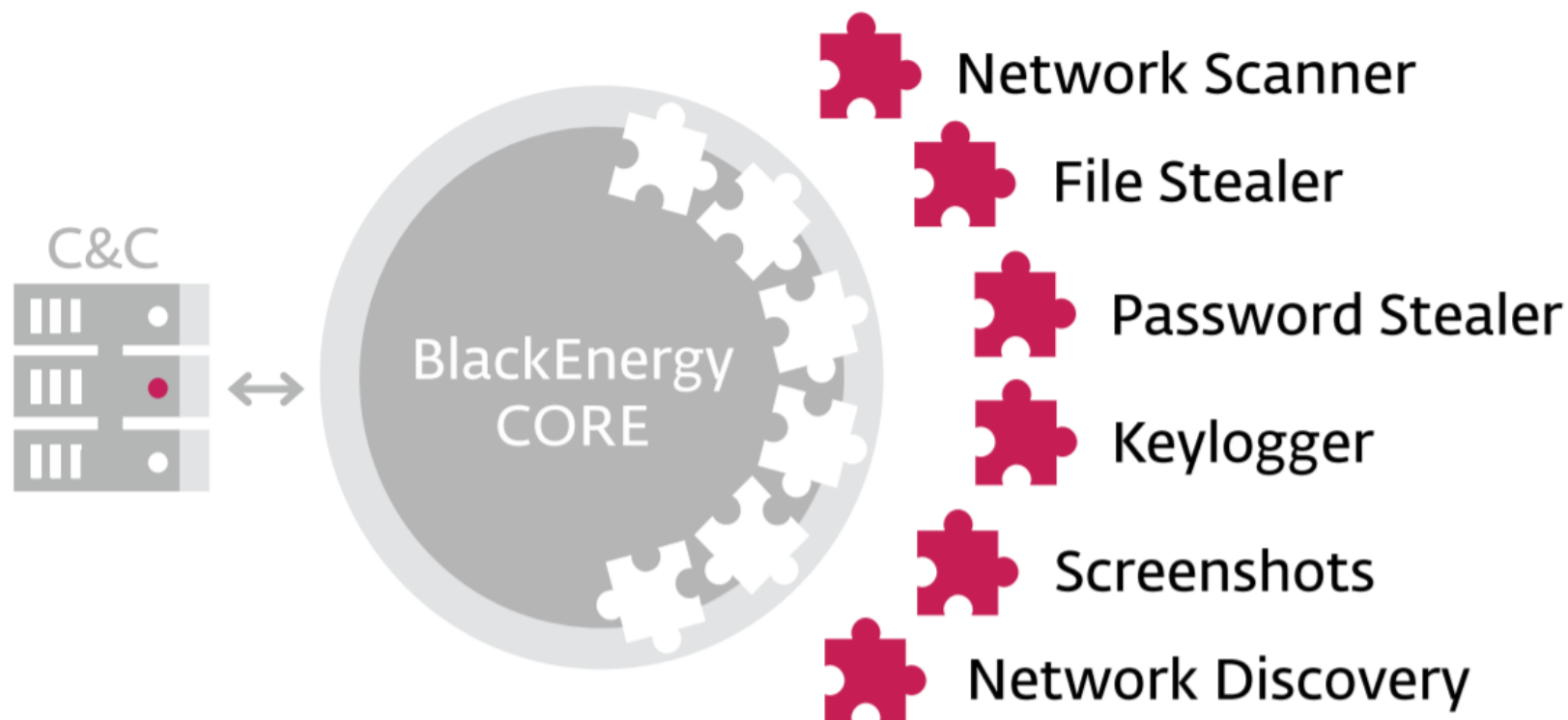
- Microsoft Office 2013 was vulnerable to an Object Linking and Embedding (OLE) bug which allowed attackers to perform remote code execution (CVE-2014-4114)
- Because of OLE bug, Microsoft Office (Excel) Macros allowed execution of Visual Basic code by anybody who opens the Microsoft Excel files
- Visual Basic code with remote code execution became the entry point of the attacker, which delivered BlackEnergy3 malware in the IT systems of grid operators

MALICIOUS.XLS

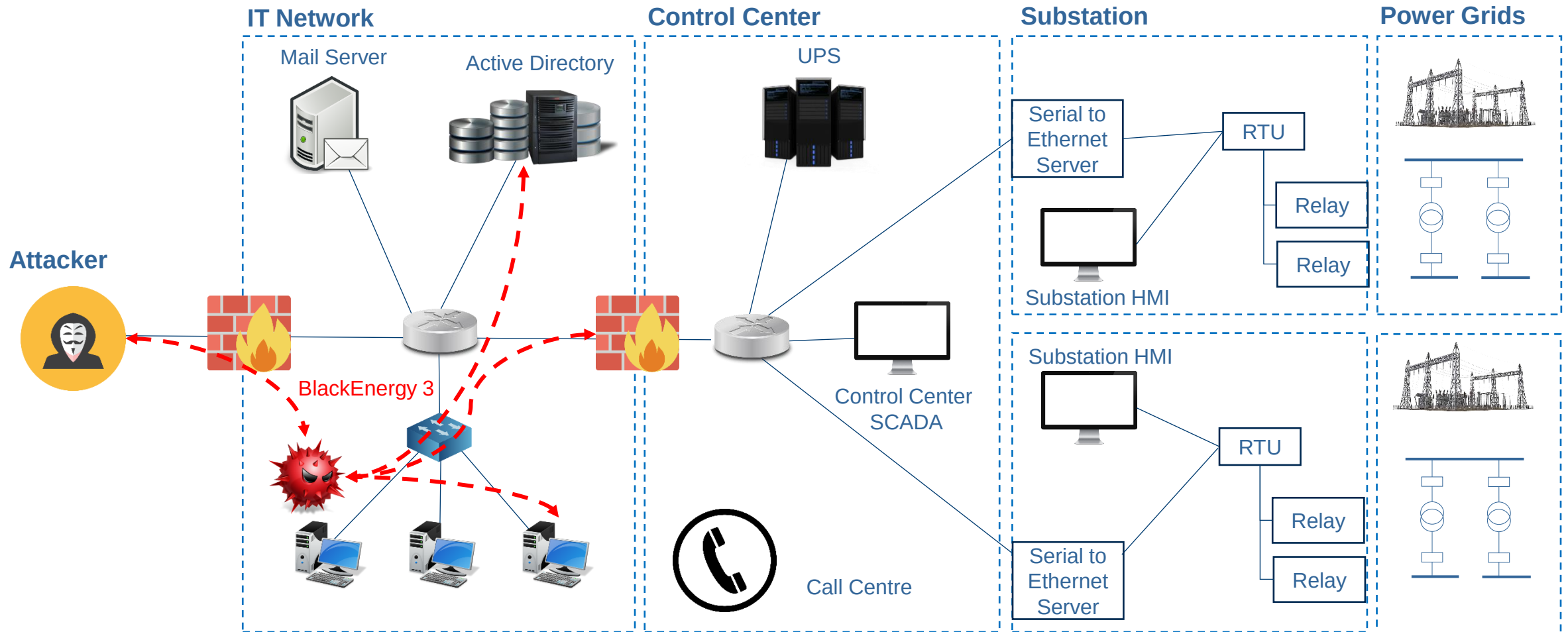
TYPE	XLS
SHA256	052ebc9a518e5ae02bbd1bd3a5a86c3560aefc9313c18d81f6670c3430f1d4d4
SHA1	aa67ca4fb712374f5301d1d2bab0ac66107a4df1
MD5	97b7577d13cf5e3bf39cbe6d3f0a7732
DETECTED	33/55
UPLOADED	First: 2015-08-03 Last: 2016-01-15

3. Weaponization BlackEnergy3 Malware

- Attackers used BlackEnergy3 as a backdoor
- It allows remote command and control
- Also used as reconnaissance tool

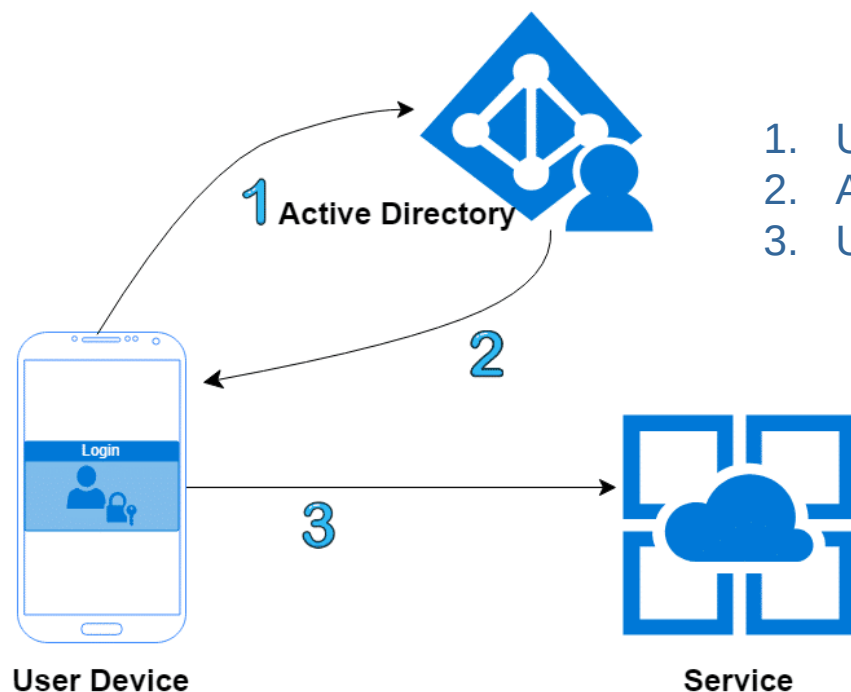


3. Weaponization BlackEnergy3 Malware



4. Credential Theft from Databases

- BlackEnergy 3 used to establish a foothold and utilize keystroke loggers to perform credential theft
- Active Directory Server compromised, possibly leading to a brute force attack on the passwords stored there
- Active Directory manages and stores information for authentication and authorization
- Adversaries used stolen credentials to gain wider access to OT system

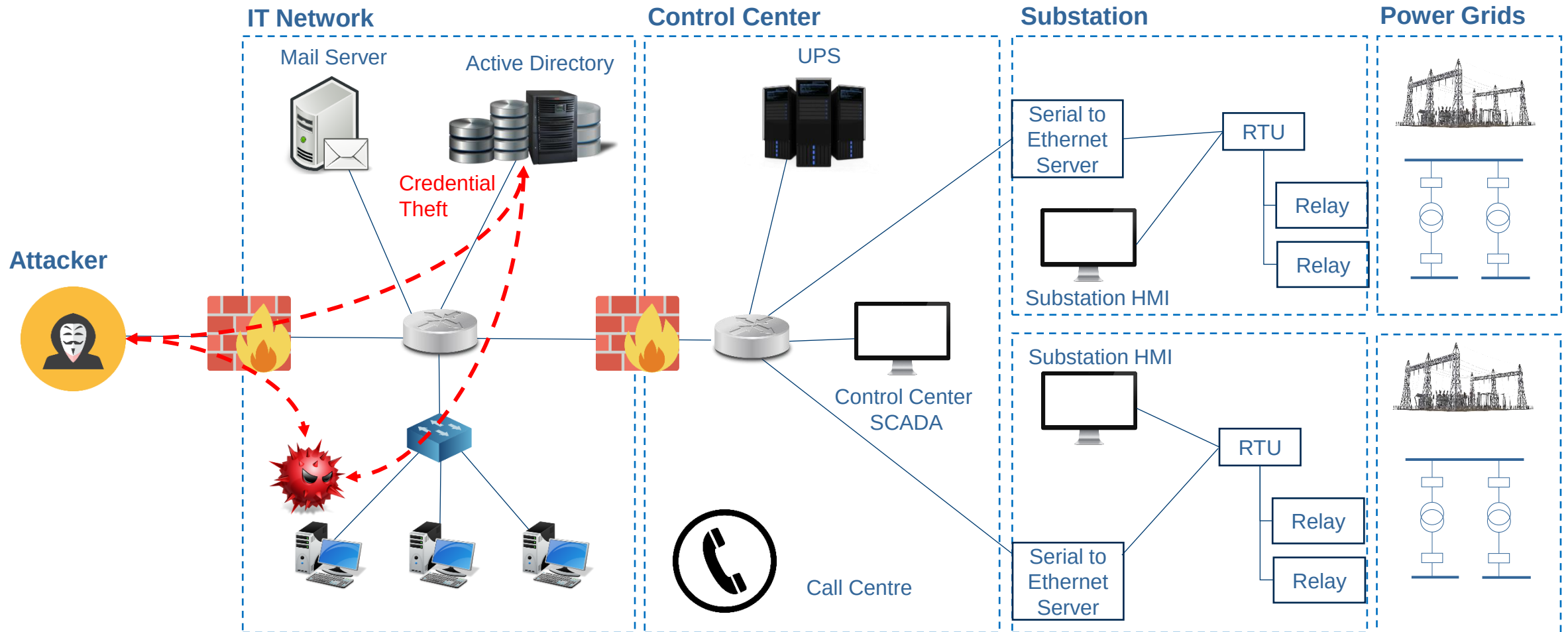


1. User authentication
2. AD grants access
3. User accesses service



Microsoft
Active Directory

4. Credential Theft from Databases

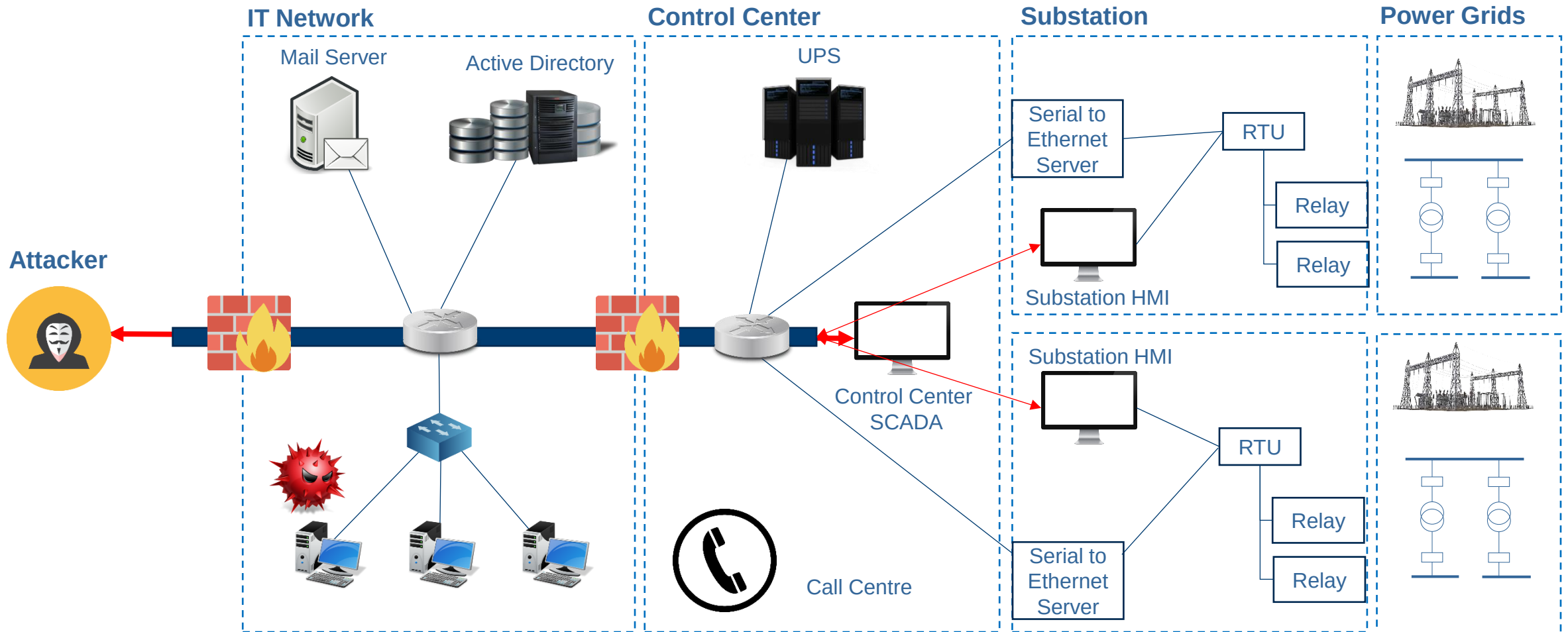


5. Remote Access Through VPN

- With the compromised credentials, attackers used an encrypted tunnel of virtual private network (VPN) to establish a presence on the Operational Technology (OT) networks
- VPN used to directly access remote computers with only username/password credentials (no two-factor authentication)
- VPN encrypted traffic is not detected by firewall
- Adversaries used standard remote access tools to gain access to control centre (OT system)
 - Remote Desktop Protocol (RDP)
 - Remote Admin (Radmin)
 - Secure Shell (SSH)

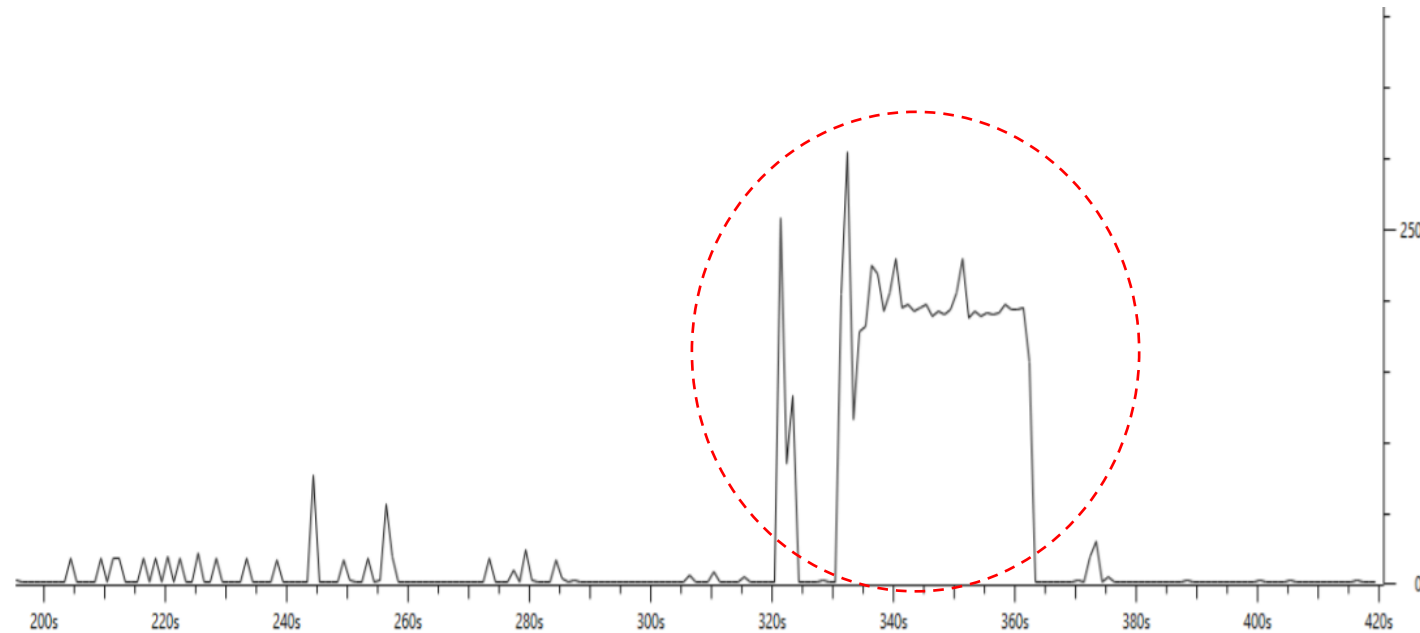


5. Remote Access Through VPN



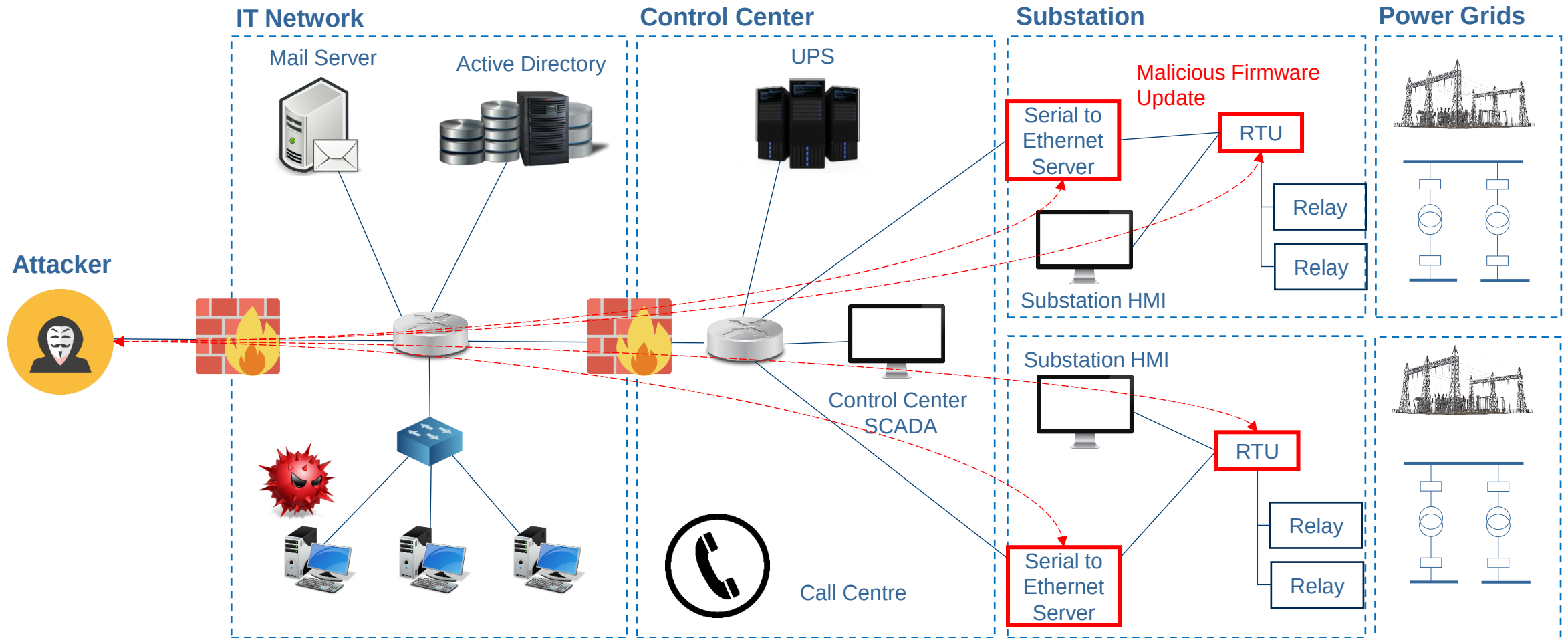
6. Remote Terminal Unit (RTU) Firmware Modification

- Adversaries modified firmware of serial-to-Ethernet converters and Remote Terminal Unit (RTU) in substations
- Vendors unable to fix the devices with compromised firmware
- Objective of firmware modifications to slow down power system restoration



Traffic Anomaly during firmware update

6. Remote Terminal Unit (RTU) Firmware Modification



7. Disable UPS Power Backup Mechanism



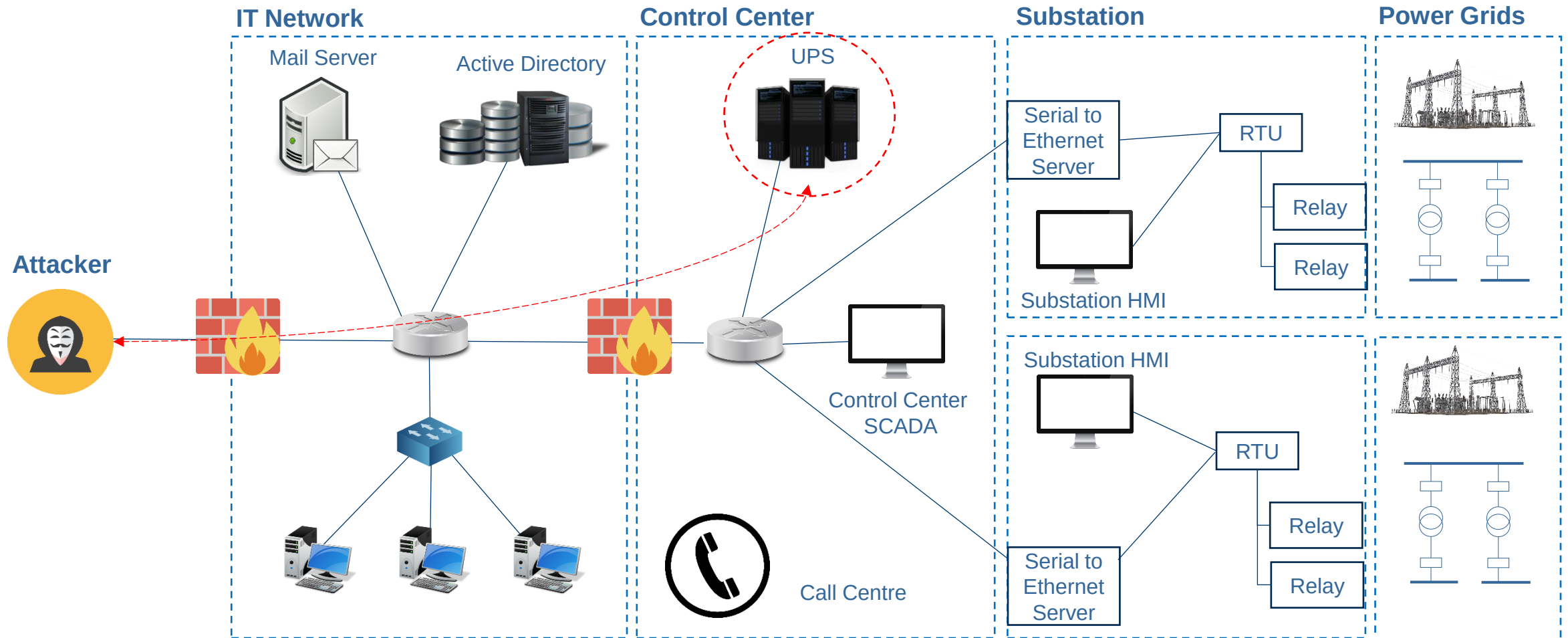
Source: Eaton.com



Source: Riello UPS

- During reconnaissance, attackers discovered network connected to Uninterruptible Power Supplies (UPS)
- UPS reconfiguration to increase final attack severity
- When the attacker caused a power outage, it was followed by an event that would also impact the power in the energy company's buildings or datacenters
- Shortly before 23rd December 2015 at 3:30 pm, attackers used the UPS remote management interfaces to schedule a shutdown of the UPS for computer servers later in the afternoon
- UPS for the server room were remotely turned off
- During attack execution, there was no power back-up for server room
- After power restoration and computers back to on, hard drives of numerous computers were corrupted

7. Disable UPS Power Backup Mechanism



8. KillDisk Overview

- KillDisk functionality part of BlackEnergy3 malware
- BlackEnergy3 framework contains a file “ololo.exe” also known to the public as KillDisk
- Actual name “ololo.exe” reference to a Russian meme
- KillDisk aimed at data destruction and creating havoc / distraction during APT operations



https://www.eecs.yorku.ca/course_archive/2016-17/W/3482/Team12_KillDisk.pdf

<https://socprime.com/blog/dismantling-killdisk-reverse-of-the-blackenergy-destructive-component/>

8. KillDisk Overview

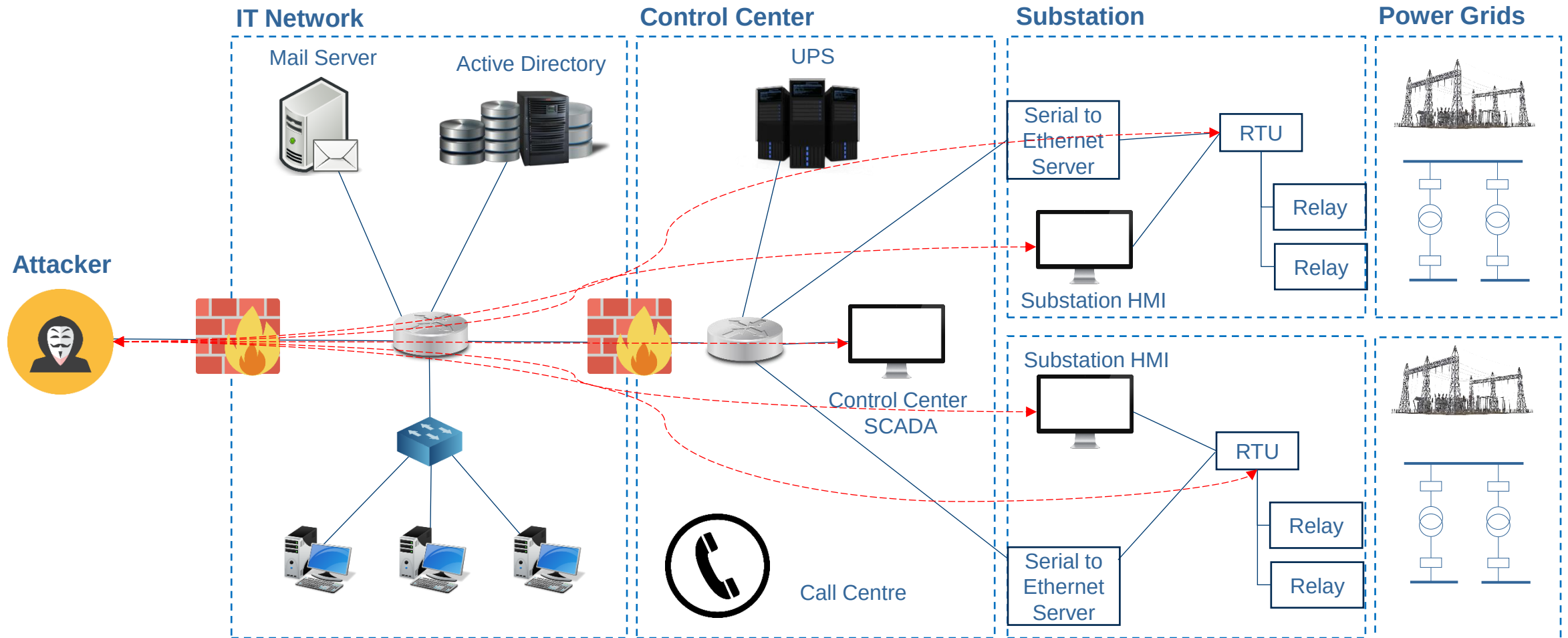
- Attackers use KillDisk to delay restoration efforts
 - Wiped out hard disks of servers in the control center
 - Erased the master boot record so that computer booting process fail
 - Deleted the logs to remove system history and hinder post incident forensic investigation
 - Deleted a process on Windows systems linked to serial-to-ethernet communications
 - Deleted daughter board in RTU devices



https://www.eecs.yorku.ca/course_archive/2016-17/W/3482/Team12_KillDisk.pdf

<https://socprime.com/blog/dismantling-killdisk-reverse-of-the-blackenergy-destructive-component/>

8. KillDisk Wiped Out Hard Disks

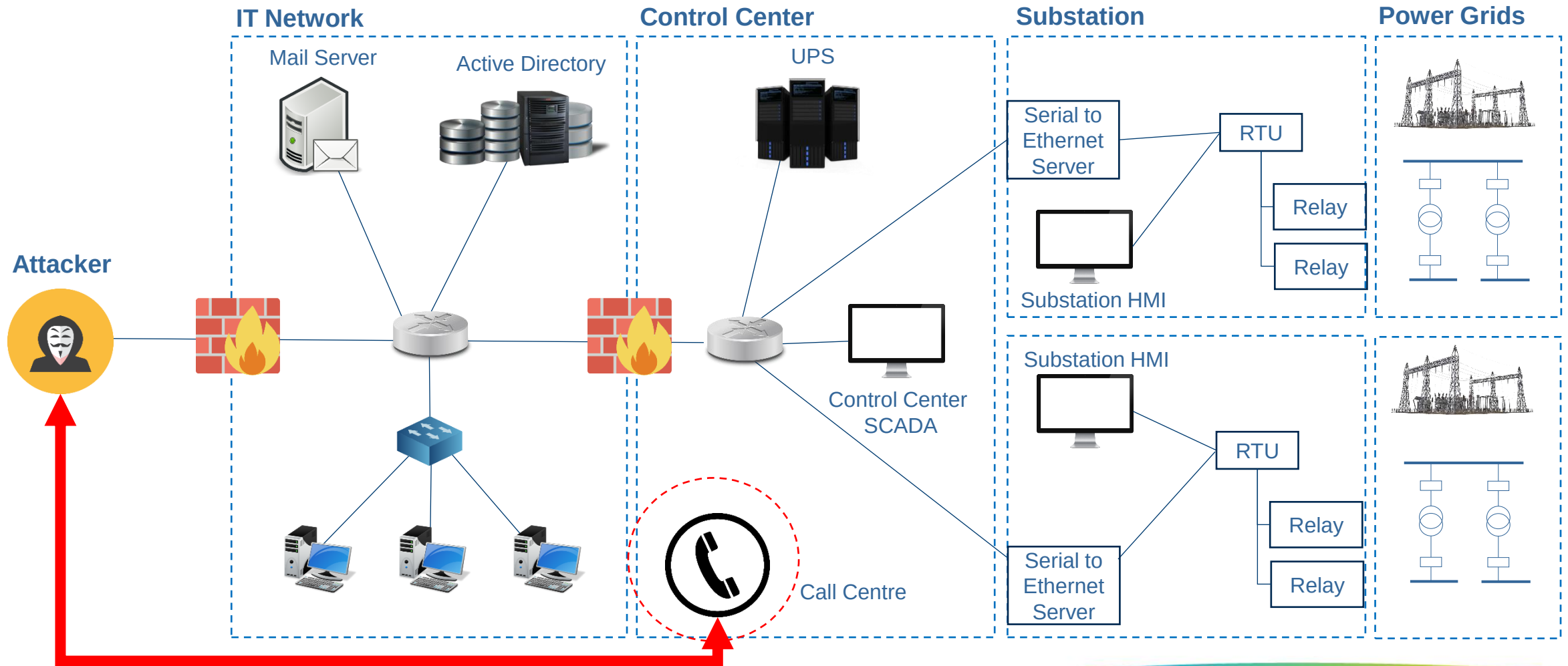


9. Telephone Denial-of-Service Attack on Call Centre

- Distribution system operators use call centres for customers to report faults
- Attackers launched a DoS attack to disrupt call centre operations and power restoration
- Call centre overwhelmed with bogus automated calls from foreign phone numbers
- Initially the Kyivoblenergo documented them as a technical failure
- Later they identified DoS was the cause of not being able to receive phone calls from customers affected by the outage



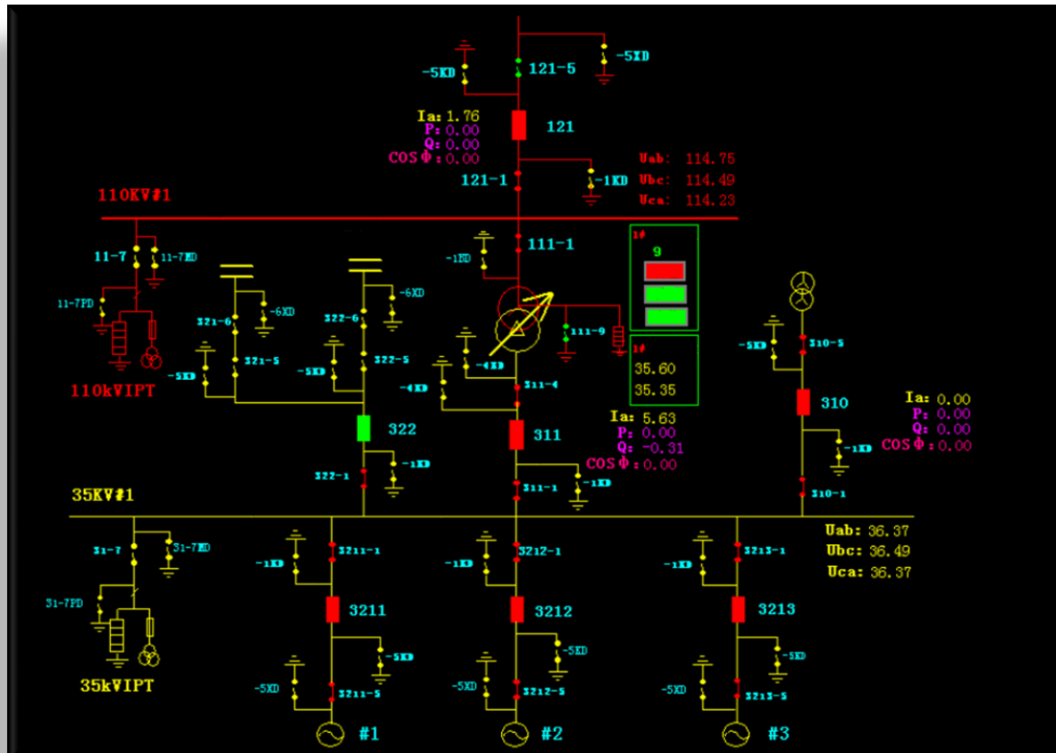
9. Telephone Denial-of-Service Attack on Call Centre



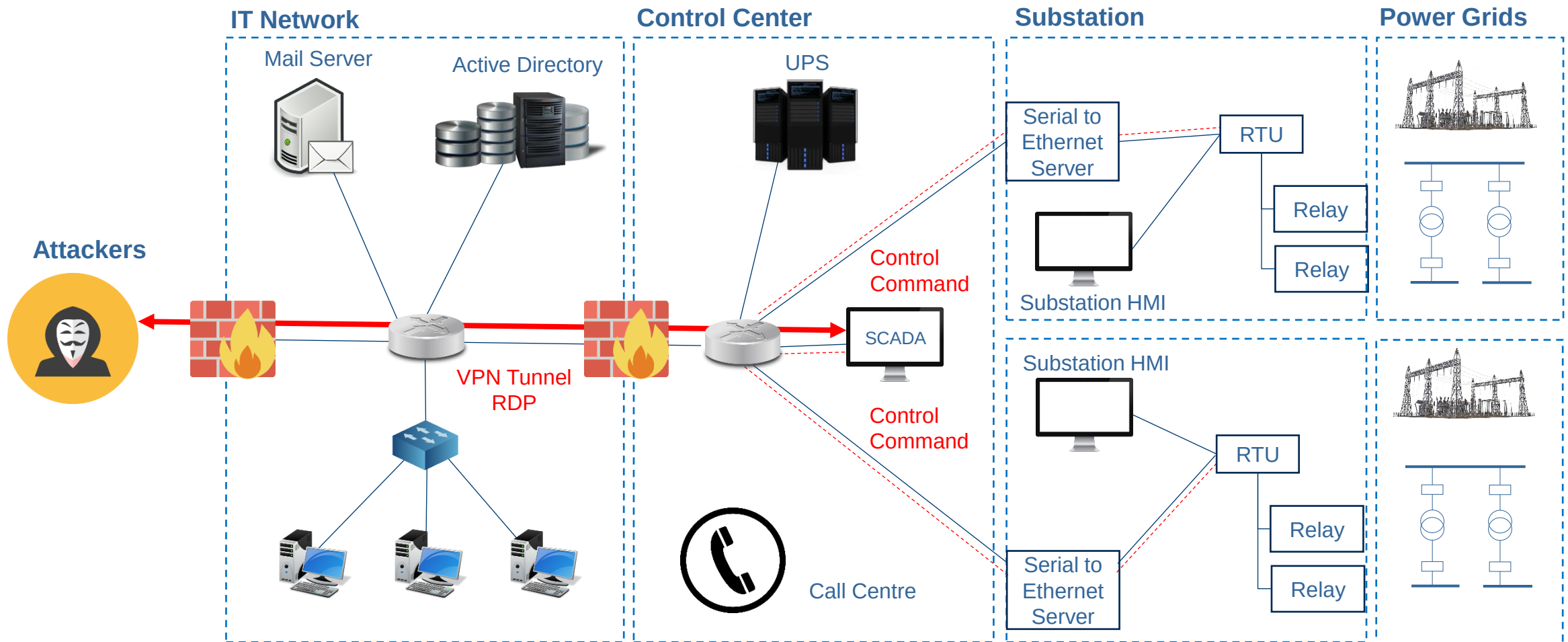
Telephone Denial-of-Service on Call Centre

10. Attack Execution on 23rd December 2015 at 3:30 pm: Remote Control of SCADA HMI

- Attackers used VPN for direct access to OT system bypassing the firewall
- Remote Desktop Protocol (RDP) used to gain access and control SCADA HMI
- **Attackers opened circuit breakers from control centre**
- RDP hijacking SCADA HMI was recorded by operators, who watched helplessly



10. Attack Execution on 23rd December 2015 at 3:30 pm: Remote Control of SCADA HMI



10. Attack Execution on 23rd December 2015 at 3:30 pm: Remote Control of SCADA HMI

**On December 23rd, 2015,
hackers caused a blackout
for roughly a quarter
million Ukrainians.**



GET IN
TOUCH

Alex Stefanov

Associate Professor, Chartered Engineer (CEng MIEI)

Email: A.I.Stefanov@tudelft.nl

Cyber Resilient Power Grids ([LinkedIn](#))

Control Room of the Future ([LinkedIn](#))

Intelligent Electrical Power Grids, EEMCS, **TU Delft**
Mekelweg 4, 2628 CD Delft, The Netherlands